

Provenance Summary

Source-to-image traceability, SLSA-style predicate analysis, builder identity, artifact digest, and attestation verification.

Field	Value
Project	Enterprise DevSecOps Security Lab
Document Owner	Jagriti Banerjee
Document Type	Provenance Summary
Environment	Private Ubuntu VM, Docker, Kind Kubernetes, GitHub Actions, GHCR
Classification	Portfolio / Private Lab Evidence
Status	Final Detailed Spacing Fixed

Document Scope

This report is part of the Enterprise DevSecOps evidence package. It is written for technical reviewers and recruiters who want to understand how artifact trust, SBOM visibility, provenance, VEX notes, and exception governance were implemented and validated in the private lab.

Reviewer Focus Area	What this document proves
Traceability	Documents repository, ref, commit, image digest, builder, and build timestamps.
Attestation	Explains how provenance is signed and verified using Cosign.
Roadmap	Identifies production improvements for trusted CI provenance and digest deployment.

Evidence Package	Included
Supply chain controls	Cosign signing, Syft SBOM, provenance attestation, Gatekeeper metadata controls
Decision records	Security gate policy, exception rules, VEX status notes, retest expectations
Release quality focus	Artifact integrity, component transparency, vulnerability triage, and audit readiness

Executive Summary

The Provenance Summary documents how the project records build origin metadata. Provenance answers where the artifact came from, which source revision produced it, which builder created it, and which digest identifies the output. The lab signs this metadata with Cosign to make the provenance tamper-evident.

SLSA-Style Scope

This lab generates SLSA-style provenance locally for learning evidence. Production pipelines should produce provenance from the CI/CD system with a trusted identity and stronger tamper resistance.

Provenance Field Review

Field	Why It Matters	Review Expectation
Repository	Links artifact to source project.	Matches expected GitHub repository.
Ref	Identifies branch or tag.	Release branches/tags should be protected.
Commit	Pins source state.	Commit should match the reviewed source.
Image digest	Pins output artifact.	Deployment should use digest rather than mutable tag.
Builder identity	Identifies build environment.	Production should use CI/OIDC identity.
Build timestamps	Supports audit timeline.	Should be generated by trusted build system.

Attestation Commands and Evidence

```
export GIT_COMMIT=$(git rev-parse HEAD)
export IMAGE_DIGEST=$(docker buildx imagetools inspect "$IMAGE" --format '{{json .Manifest.Digest}}' | tr -d '"')

cosign attest --key security/cosign/cosign.key --predicate security/provenance/slsa-provenance.json --type slsaprovenance "$IMAGE"

cosign verify-attestation --key security/cosign/cosign.pub --type slsaprovenance "$IMAGE" | tee security/reports/slsa-provenance-verify.txt
```

Threat Scenarios Controlled by Provenance

Threat	How Provenance Helps	Remaining Gap
Unreviewed source built into image	Provenance links image to repository and commit.	Local provenance must be trusted manually.
Registry tag replaced	Digest can reveal tag drift.	Deployments should use digest pinning.
Unknown build environment	Builder field identifies build source.	CI identity is stronger than self-declared VM identity.
Metadata tampering	Cosign attestation verification detects alteration.	Admission verification is not automated yet.

Production Hardening Roadmap

- Generate provenance from GitHub Actions using trusted workflow identity.
- Use protected branches and required reviews before builds can release artifacts.
- Sign image digests, not only tags.
- Verify provenance during deployment promotion.

- Store provenance and SBOM together in a release evidence bundle.
- Add alerting when deployment image digest does not match signed provenance.

References

- CISA VEX minimum requirements: <https://www.cisa.gov/sites/default/files/2023-04/minimum-requirements-for-vex-508c.pdf>
- OpenVEX specification: <https://github.com/openvex/spec/blob/main/OPENVEX-SPEC.md>
- SLSA specification: <https://slsa.dev/spec/v1.2/>
- SLSA provenance specification: <https://slsa.dev/spec/v1.0/provenance>
- Sigstore Cosign project: <https://github.com/sigstore/cosign>
- Cosign specifications and attestation support: https://docs.sigstore.dev/cosign/system_config/specifications/
- Sigstore project overview: <https://www.sigstore.dev/>